

北 京 邮 电 大 学

本科毕业设计（论文）开题报告

|          |                                                                                                                                  |      |            |      |            |
|----------|----------------------------------------------------------------------------------------------------------------------------------|------|------------|------|------------|
| 学院       | 网络空间安全学院                                                                                                                         |      | 专业         | 信息安全 |            |
| 学生姓名     | 张艺翱                                                                                                                              | 学号   | 2022211575 | 班级   | 2022211801 |
| 指导教师姓名   | 张淼                                                                                                                               | 所在单位 | 北京邮电大学     | 职称   | 副教授        |
| 设计（论文）题目 | （中文）基于强化学习的 Web 渗透测试大模型增强算法的研究与仿真                                                                                                |      |            |      |            |
|          | （英文） Research and Simulation of Large-Scale Web Penetration Testing Model Augmentation Algorithm Based on Reinforcement Learning |      |            |      |            |

毕业设计（论文）开题报告内容：（主要包含选题的背景和意义；研究的基本内容和拟解决的主要问题；研究方法；研究工作的步骤与进度；主要参考文献等项目。不少于 1500 字）

一、选题的背景和意义

随着 Web 应用在政企系统、互联网业务与云原生架构中的广泛部署，Web 攻击面持续扩大，渗透测试作为“以攻促防”的关键手段，被广泛用于发现系统漏洞、验证安全风险与提升整体防护能力。然而，传统渗透测试高度依赖人工经验与工具链编排，面对复杂目标时往往需要多轮信息收集、漏洞验证、权限维持与错误恢复等过程，成本高、周期长且难以规模化。近年来大语言模型（LLM）在代码理解、自然语言推理与工具调用方面表现突出，使得“由模型驱动的自动化渗透测试”成为可能，但现实挑战依然显著：模型在真实渗透流程中常出现错误处理能力不足、推理链条冗长低效、难以在多步任务中保持目标一致性、以及缺乏基于环境反馈的自我纠错能力等问题。近期相关研究普遍指出，自动化渗透测试对提升网络安全具有重要价值，但现有大语言模型在该领域仍存在错误处理差、推理低效、难以端到端自主完成复杂任务等关键限制。因此，有必要引入基于环境反馈的强化学习训练，使模型在交互式 CTF 场景中逐步学习更稳定的自适应策略与纠错能力。

从研究发展趋势看，让大语言模型在交互环境中基于反馈信号进行强化学习训练，正在成为提升安全任务可靠性的重要方向。一方面，安全任务不仅需要生成看似合理的解释，更需要能区分“表面可信但错误”的结论。有研究通过强化学习与结构化推理蒸馏来提升漏洞检测场景下推理的可靠性与可用性，强调模型要学习产出可执行、可验证、可复核的安全评估结论。另一方面，面向大模型的强化学习训练也可能出现奖励过优化或策略投机等问题，从而导致模型在训练环境中表现提升但泛化能力不足。因此，需要在奖励设计、训练监控与评估指标上采取更稳健的措施，以降低训练偏差并提升策略可靠性。因此，将“Web 渗透测试的真实交互闭环”与“强化学习策略优化”结合起

来，既具有明确的工程应用价值，也具有学术研究意义：它有望让渗透测试从“脚本与规则驱动”进一步迈向“通过环境反馈自我进化的智能体”，从而提升自动化渗透测试在复杂目标上的成功率、稳定性与可迁移性。

基于上述背景，本课题以“基于强化学习的 Web 渗透测试大模型增强算法的研究与仿真”为目标，拟构建可交互的 CTF 靶场与渗透测试环境，形成 LLM 的“观察—思考—行动”闭环，并基于 PPO/GRPO 等策略优化方法对模型进行增强训练与对照评估。该研究有望在实践上沉淀一套可复现的渗透测试训练与评估流程，在理论上探讨奖励设计、训练稳定性与策略泛化能力等关键问题，对推动 AI 赋能渗透测试的研究与应用具有积极意义。

## 二、研究的基本内容和拟解决的主要问题

本课题的研究内容围绕“环境—交互—奖励—训练—评估”的完整链路展开，整体工作与任务书保持一致：先通过文献调研明确技术路线，再搭建含多类典型漏洞的交互式 CTF 靶场，随后实现 LLM 与环境的闭环交互与轨迹记录，在此基础上设计奖励函数并构建强化学习环境，最终实现基于 PPO/GRPO 的增强训练框架，并通过系统性实验评估方法有效性，完成论文撰写与答辩。具体而言，靶场将覆盖 SQL 注入、命令执行、文件上传等典型 Web 漏洞并支持多步攻击链路，同时提供稳定的程序化接口以便自动化执行；交互闭环将把 URL、参数、会话状态、历史请求与响应等信息编码为模型可用的状态表示，并将模型输出映射为可执行动作，从而产生可用于训练的轨迹数据；强化学习部分将以渗透测试阶段性目标为依据构造奖励与惩罚机制，使模型能从环境反馈中学习更鲁棒的策略；训练与集成部分将实现 PPO 或 GRPO 等策略优化流程，完成从数据采样到优势估计、策略更新与系统联调的一体化；最后通过对照实验从成功率、漏洞覆盖率、平均步数与请求数等角度评估增强效果。

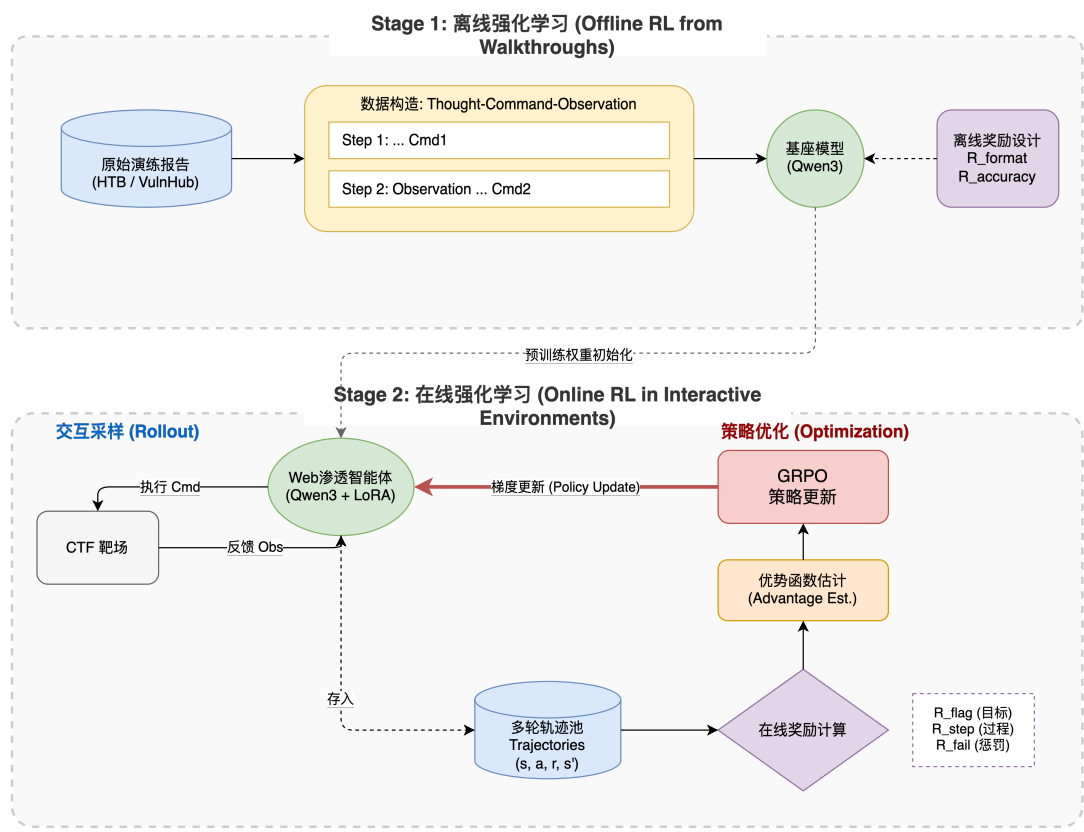
围绕上述内容，本课题拟重点解决的主要问题可概括为三个层面。第一是“渗透测试任务如何被形式化为可训练的交互环境”：Web 渗透本质上是多阶段、多分支的决策过程，状态信息复杂且部分可观测，若状态表示不合理、动作空间不受控或终止条件不明确，会导致训练不稳定或策略学不到关键能力。第二是“奖励函数如何有效刻画渗透测试的阶段性进展”：单纯以最终拿到 flag 作为稀疏奖励往往难以学习，而过于密集的启发式奖励又可能引入偏差甚至诱发奖励过优化或策略投机，因此需要结合关键事件（漏洞发现、利用成功、敏感信息获取、错误恢复等）设计分层或组合奖励，并在训练中持续校验其合理性与鲁棒性。第三是“如何在 LLM 强化学习训练中兼顾效率与稳定性”：大模型训练成本高且易出现过优化、策略崩塌或对特定靶场过拟合等问题，需要在算法选择、采样

策略、超参设置与训练监控方面形成可复现的工程方案，并通过对照实验与消融分析解释增强效果来源。上述问题的解决将直接决定最终系统能否在交互式 CTF 场景中实现稳定提升，并为后续扩展到更复杂 Web 目标提供基础。

### 三、研究方法及措施

本课题拟采用“工程系统构建与两阶段强化学习算法优化相结合”的综合研究路线。针对大语言模型在渗透测试任务中普遍存在的长链路推理效率低、错误恢复能力差以及缺乏动态适应性问题，本研究将构建一套基于 Qwen3 基座模型的自动化渗透测试系统。整体方法论遵循“离线知识内化（Offline RL）”到“在线实战进化（Online RL）”的渐进式策略，利用群组相对策略优化算法（GRPO）在无需训练独立价值网络的情况下实现高效的策略增强。

为了更直观地展示工作流程，以下是本课题的总体系统架构图，涵盖了从数据处理到在线交互训练的完整过程。



#### 1. 渗透测试数据构建与离线冷启动训练

研究的首要步骤是解决高质量渗透测试推理数据稀缺的问题。本研究将从 HackTheBox、VulnHub 等主流靶场平台收集真实的渗透测试演练报告（Walkthroughs），构建包含多样化攻击场景的原始数据集。鉴于原始报告通常仅记录操作指令而缺乏中间的思维过程，本研究将利用辅助的高性能大模型

对数据进行“思维链逆向工程”，将原始数据重构为标准化的“(思维 Thought - 指令 Command - 观察 Observation)”三元组格式。在此基础上，采用离线 GRPO 算法对 Qwen3 模型进行初步微调。为了引导模型掌握基础的攻击逻辑和输出规范，本研究设计了复合离线奖励函数：一方面通过“格式奖励”鼓励模型生成规范的 <think> 标签和步骤头，确保推理过程的结构化；另一方面通过“准确性奖励”计算生成指令与专家轨迹的匹配度（如 Jaccard 相似度），从而在训练初期快速赋予模型基础的渗透测试领域知识。

## 2. 交互式靶场环境与在线强化学习

在模型具备基础能力后，研究将进入核心的在线强化学习阶段。本研究将基于 Docker 容器技术搭建高保真的交互式 CTF 靶场，环境涵盖 SQL 注入、命令执行（RCE）、文件上传等典型 Web 漏洞场景，并参考 InterCode-CTF 标准实现程序化的交互接口。在该阶段，模型将与靶场进行实时交互，通过执行 Shell 命令或构造 HTTP 请求来尝试获取 Flag。

为了解决传统强化学习算法（如 PPO）显存占用高且难以处理长文本的问题，本研究将采用 GRPO 算法进行在线策略优化。该算法不依赖 Critic 网络，而是通过对同一状态并行采样多条攻击轨迹，计算每条轨迹相对于组内平均回报的优势函数（Advantage）来更新策略。在线奖励函数的设计将结合稀疏奖励与密集奖励：当模型成功获取 Flag 时给予高额的正向终值奖励（如 +1.0）；对于每一个语法正确且成功执行的中间步骤，给予微小的过程奖励（如 +0.05）以鼓励探索；而对于执行报错或超时的情况，则施加惩罚（如 -0.1），迫使模型学习自我纠错和路径修正。通过这种“试错-反馈-修正”的闭环训练，模型将逐步习得在复杂动态环境中保持目标一致性并处理突发错误的高级能力。

## 3. 系统集成与多维评估验证

在工程实现层面，本研究将基于 Python 开发自动化训练框架，集成 TRL 或 VERL 等强化学习库，利用 LoRA（Low-Rank Adaptation）技术降低大模型微调的显存需求，确保在有限算力下的训练可行性。实验评估环节将选用 Cybench 和 AutoPenBench 两个权威基准数据集进行测试。评估指标不仅关注攻击成功率，还将重点量化模型的“Token 消耗量”，以验证强化学习是否有效提升了推理的直接性和高效性。此外，研究还将通过消融实验，分别移除离线训练阶段或在线交互阶段，对比不同配置下的模型表现，从而定量分析两阶段训练机制对最终渗透能力的具体贡献。

## 四、研究工作的步骤与进度

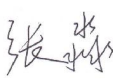
本课题研究步骤与进度严格对应任务书安排。第一阶段为 2025 年 12 月 7 日至 2026 年 3 月 7 日，主要进行大量中外文献阅读与高质量论文研读，完成 Web 渗透测试自动化、强化学习与大语

言模型方向的现状梳理,明确研究内容与技术路线,细化课题任务并完成开题报告。第二阶段为 2026 年 3 月 8 日至 2026 年 3 月 29 日,完成交互式 CTF 靶场的搭建与调试,设计与实现程序化访问接口,完成 LLM 交互闭环、奖励函数及强化学习环境的基本功能,实现可运行的系统原型。第三阶段为 2026 年 3 月 30 日至 2026 年 4 月 17 日,完成中期检查,并开展实验结果的综合分析与对比研究,发现不足并进行优化改进。第四阶段为 2026 年 4 月 18 日至 2026 年 5 月 30 日,根据实验结果持续完善系统,补充整理实验数据与图表,完成毕业论文撰写与修改,准备答辩材料并完成论文答辩。

在具体执行上,将以“可运行版本优先”的方式推进:先尽快完成最小可用靶场与交互闭环,确保能够产生有效轨迹;再逐步丰富漏洞类型与攻击链路、完善奖励设计与训练流程;最后集中力量做实验对照、消融分析与论文材料整理,以保证中期检查与最终答辩节点按期完成。

## 五、主要参考文献

- [1] Kong H, Hu D, Ge J, Li L, Li H, Li T. Pentest-R1: Towards Autonomous Penetration Testing Reasoning Optimized via Two-Stage Reinforcement Learning[EB/OL]. arXiv:2508.07382, 2025.
- [2] Weyssow M, Yang C, Chen J, Li Y, Huang H, Ang H W, et al. R2Vul: Learning to Reason about Software Vulnerabilities with Reinforcement Learning and Structured Reasoning Distillation[EB/OL]. arXiv:2504.04699, 2025.
- [3] Yu T, Liu L, Zhou Z, Xing F, Wang K, Yang Y. REFN: A Reinforcement-Learning-From-Network Framework against 1-day/n-day Exploitations[EB/OL]. arXiv:2508.10701, 2025.
- [4] Wang Z, Wang K, Wang Q, Zhang P, Li L, Yang Z, et al. RAGEN: Understanding Self-Evolution in LLM Agents via Multi-Turn Reinforcement Learning[EB/OL]. arXiv:2504.20073, 2025.
- [5] Simoni M, Fontana A, Rossolini G, Saracino A. Improving LLM Reasoning for Vulnerability Detection via Group Relative Policy Optimization[EB/OL]. arXiv:2507.03051, 2025.
- [6] Muzsai L, Imolai D, Lukács A. Improving LLM Agents with Reinforcement Learning on Cryptographic CTF Challenges[EB/OL]. arXiv:2506.02048, 2025.
- [7] Islam N T, Khoury J, Seong A, Bahrami Karkevandi M, De La Torre Parra G, Bou-Harb E, Najafirad P. LLM-Powered Code Vulnerability Repair with Reinforcement Learning and Semantic Reward[EB/OL]. arXiv:2401.03374, 2024.
- [8] Jin B, Zeng H, Yue Z, Yoon J, Arik S, Wang D, Zamani H, Han J. Search-R1: Training LLMs to Reason and Leverage Search Engines with Reinforcement Learning[EB/OL]. arXiv:2503.09516, 2025.
- [9] Miao Y, Zhang S, Ding L, Bao R, Zhang L, Tao D. InfoRM: Mitigating Reward Hacking in RLHF via Information-Theoretic Reward Modeling[C]//Advances in Neural Information Processing Systems (NeurIPS). 2024.

|                                                                                   |                  |                |                                                                                     |
|-----------------------------------------------------------------------------------|------------------|----------------|-------------------------------------------------------------------------------------|
| 允许进入毕业设计（论文）下一阶段：是 <input checked="" type="checkbox"/> 否 <input type="checkbox"/> |                  | 指导教师<br><br>签字 |  |
| 日期                                                                                | 2025 年 12 月 23 日 |                |                                                                                     |

注：可根据开题报告的长度加页